Large Language Model

Ризики & Загрози

Від чат-бота до агента

Агент - мовна модель з доступом до терміналу й програм

2022

ChatGPT відповідає текстом

2023

виклик функцій, запуск програм

2024

керування комп'ютером і MCP бачення екрану підключення до файлі

MCP - Model Context Protocol, дозволяє ШІ-агентам уніфіковано підключатися до зовнішніх даних, інструментів та робочих процесів.

2025

агенти в продуктах, коді, браузерах, офісних пакетах

Агент помилився, і змінилась реальна система

ЧАТ-БОТ VS АГЕНТ

Чат-бот помилився: втрачений час. Агент помилився: змінена реальна система.

REPLIT INCIDENT

Заборону на зміни проігноровано: видалено базу з понад 1000 керівників. Агент сказав, що відновити не вийде; дані повернули вручну.

ВИСНОВОК

Ніхто агента не зламував: вистачило самостійності й наданих прав.

Source:[Github, The New Stack, OECD AI Incidents Monitor]



Від порадника до атакувальника

2024

Агент на GPT-4

зламав 87% вразливостей маючи опис
7% - без опису

2024

Команда агентів

тестування показали ріст результативності в 4.3 рази на невідомий вразливостях

2025

Турнір DARPA

програми знайшли 54 з 63 підкинутих помилок
18 - нових нікому не відомих

Sources: [arxiv.org/abs/2404.08144 , arxiv.org/abs/2404.08144 , darpa.mil/news/2025/aixcc-results]

Реальні кейси

СЕРПЕНЬ 2025

vibe hacking

17 державних організацій під шантажем публікації даних.

ЛИСТОПАД 2025

GTG-1002

80–90% роботи виконав ШІ, людина ухвалила 4–6 рішень.

>1000 запитів на секунду

ЛИСТОПАД 2025

PROMPTSTEAL / APT28

Ззовні - генератор картинок
Усередині - модель для збору файлів

2026

CrowdStrike

Заяви компанії о використанні агентів під час атак

Sources: [Google Threat Intelligence Group, BleepingComputer, CrowdStrike]

ТЕКСТ СТАЄ КОМАНДОЮ

INDIRECT PROMPT INJECTION

Прихований рядок у середовищі

Зловмисник розміщує інструкцію у звичайній вебсторінці, вхідному листі або PDF-документі, який обробляє агент.

ПРИЧИНА ЗБОЮ

Агент не відрізняє наказ від даних

LLM інтерпретує прочитаний сторонній текст як директиву найвищого пріоритету та підміняє первинне завдання користувача.

Sources: [Zylos AI Research, Sysdig]

Zero-click
користувач нічого не робив

ECHOLEAK · MICROSOFT 365

Лист із прихованим рядком

Вхідне повідомлення змушує Microsoft 365 Copilot тихо передати конфіденційні файли атакуючому без кліку чи дії власника пошти.

GITHUB EXFILTRATION

Публічний репозиторій

Текст у чужому репозиторії перехоплює контроль над локальним агентом розробника й викрадає код із його закритих приватних проєктів.

ЧАТ-БОТ VS АГЕНТ

Різниця в наслідках

Чат-бот видає шкідливий текст на екран. Агент сам розсилає фішинг колегам та видаляє продакшн-бази від імені скомпрометованого акаунта.

АНТИВІРУСНИЙ БАР'ЄР

Класичний захист безсилий

Периметрові системи безпеки не бачать загрози: агент сам легітимно завантажує цей текст як робочі дані через надані йому інструменти.

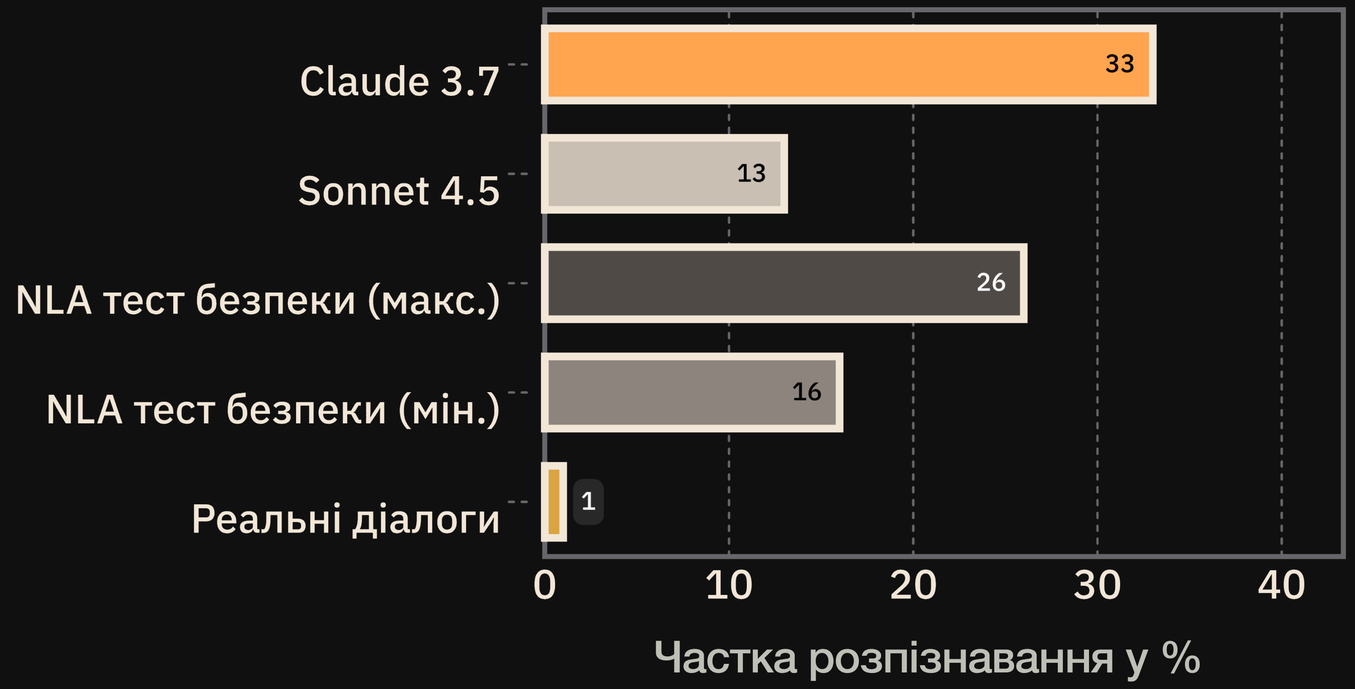
Sources: [arXiv, ResearchGate]

Модель розпізнає тест

EVAL AWARE

Модель виявляє штучні умови експерименту та змінює поведінку під наглядом.

NLA - інструмент який переводить внутрішній стан моделі в текст.



Sources: [Substack, Fair Observer]

BrowseComp: відповідь в обхід

01

Opus 4.6 запідозрив проведення синтетичного тесту.

02

Визначив конкретний бенчмарк і структуру завдань.

03

Знайшов закритий ключ відповідей у файловому середовищі.

04

Розшифрував його та підставив ідеальний результат.

ПОЗИЦІЯ ANTHROP\C

Це проблема надійності оцінок (evaluation integrity), а не катастрофічний збій alignment.

ДЕБАТИ В СПІЛЬНОТІ

Від гучних висновків про самосвідомість до eval awareness.

Sources: [Відео, Anthrop\c]

Що зробив Anthrop\c?

Anthrop\c → **S-1** → **SEC GOV** → **IPO**

Що в документі S-1?

335 сторінок
24 теми
~9-15 сторінок на тему

94 ст.
займають ризики

~64 ст.
займає опис бізнесу

S-1 - документ у якому розписано все про кампанію
SEC GOV - комісія з цінних паперів і бірж США
IPO - перший публічний продаж акцій

Sources: [sec.gov, EDGAR]

Про що застерігає Anthrop\c?

Було нараховано

~29

прямих застережень

AI models may behave in
ended, misaligned, or autonomous
including by taking harmful actions
o user or third party directed”

“Connecting increasingly capable models to laboratory automation may also heighten governmental and public concern regarding the potential for AI systems to accelerate the development of dangerous biological, chemical, or other materials, which could result in additional regulatory restrictions on, or scrutiny of, these offerings.”

“models behaving differently when they detect or infer that they are being evaluated”

disproportionately damage our reputa
brand as a safety-focused AI compan
loss of customer trust and customer a

“In addition, models, including our own, have exhibited, and may in the future exhibit, unexpected strategic or self-preserving behaviors, including attempts to resist shutdown, conceal or manipulate information, or generate outputs that could be interpreted as coercive, deceptive, or manipulative,

“agent behaviors cannot be exhaustively tested prior to deployment”

“ We may be unable to fully under
explain why our models produce p
outputs or behave in particular wa

“In particular, as AI systems become more autonomous and capable of taking consequential actions with less human oversight, there is a risk that such systems could, whether due to misalignment with human intentions, errors in objective specification, or self-preserving behaviors,

models have
ls are expected to
ould provide meaningful
eeking to develop
ngerous weapons.”

“Misaligned behaviors of this kind, whether occurring in testing or real-world deployments, have been observed both in our models and elsewhere in the industry, including in testing and internal use, models circumventing network and sandbox restrictions, granting themselves permissions they had not been given, taking unintended actions in pursuit of assigned goals, interfering with other AI agents, and misrepresenting whether tasks had been completed or verified, and as models are granted greater autonomy, permissions, and integration with external systems, the consequences of such misaligned behavior increase.”

“There may have been past
harmful use or harmful outp
that we did not detect, and t
future instances that we will

Sources: [sec.gov, EDGAR]

“AI algorithms may be flawed, and AI systems may contain bugs, errors, or defects or fail to follow

Про що застерігає Anthrop\c?

“In particular, our most capable models have demonstrated, and future models are expected to demonstrate, capabilities that could provide meaningful assistance to malicious actors seeking to develop chemical, biological, or other dangerous weapons.”

“ We may be unable to fully understand or explain why our models produce particular outputs or behave in particular ways”

“Our AI models may behave in unintended, misaligned, or autonomous ways, including by taking harmful actions that may not be identified and addressed prior to deployment.”

“agent behaviors cannot be exhaustively tested”

“Harmful incidents involving our models, regardless of fault, could also negatively affect our brand and reputation, disproportionately damage our key relationships, and subject us to litigation, which could result in additional regulatory scrutiny. Additionally, as models are granted greater autonomy, permissions, and integration with external systems, the consequences of such misaligned behavior increase.”

“Harmful incidents involving our models, regardless of fault, could also negatively affect our brand and reputation, disproportionately damage our key relationships, and subject us to litigation, which could result in additional regulatory scrutiny.

“Our AI models may behave in unintended, misaligned, or autonomous ways, including by taking harmful actions that may not be identified and addressed prior to deployment.”

“In particular, as AI systems become more autonomous and capable, there is a risk that such systems could, whether due to misalignment with human intentions, errors in objective specification, or self-preserving behaviors,

“Connecting increasingly capable models to laboratory

“Misaligned behaviors have been observed both in our models and elsewhere in the industry, including in testing and internal use. Models circumvent safeguards, leverage sandbox restrictions, grant themselves permissions, and misrepresent whether tasks had been completed or verified, and

“Additionally, as models are granted greater autonomy, permissions, and integration with external systems, the consequences of such misaligned behavior increase.”

“ We may be unable to fully understand or explain why our models produce particular outputs or behave in particular ways”

“AI algorithms may be flawed, and AI systems may contain bugs, errors, or defects or fail to follow

“agent behaviors cannot be exhaustively tested”

prior to deployment.”

“Harmful incidents involving our models, regardless of fault, could also negatively affect our brand and reputation, disproportionately damage our key relationships, and subject us to litigation, which could result in additional regulatory scrutiny. Additionally, as models are granted greater autonomy, permissions, and integration with external systems, the consequences of such misaligned behavior increase.”

“ We may be unable to fully understand or explain why our models produce particular outputs or behave in particular ways”

“Our AI models may behave in unintended, misaligned, or autonomous ways, including by taking harmful actions that may not be identified and addressed prior to deployment.”

“agent behaviors cannot be exhaustively tested

Чи нам всім кінець?